Tribal ID Verification: Testing Plan (Oct 24, 2026)

Six test areas for the tribal ID verification and flat 20% discount, with owners, PASS/FAIL criteria and rollback steps. Nothing has been run yet.

Display & Cell Pros LLC. Prepared for Ryan Young. This is the teams' own planning, with no lawyer or CPA review (Finance is not a licensed CPA). Status as of Oct 24, 2026: every test is Not run.

Discount	Flat 20%, never variable. One per order, no combining.
Starts	Nov 1, 2026 12:00 AM PT
TRIBAL_VERIFY_...	OFF
TRIBAL_TAX_EXE...	OFF, stays off
Test customer	Ryan's own record, tagged tribal-member-verified
Slack	App "DCP Tribal Approvals" in private #tribal-approvals (C0CBP9AGWKV). Approver: Ryan (U0C3N2P94K1).
Code	PR #78 merged by Gitty with Ryan's OK. Production deployed.

⚠ Needs Ryan's decision

1. Before Nov 1: Option A (offline runs plus a checkout showing no discount; recommended) or Option B (move the discount start to now for Ryan's account only, then restore it)?
2. Approve Gitty turning the code tests into a PR? Tell Gitty in Gitty's own chat.
3. Whole-dollar rounding, or keep cents (for example $197.60)?
4. Strict or faster approval for verification (your earlier open decision)?
5. Mail-in has no products yet, so mail-in discount behavior stays untested live. Okay for now?
6. Lawyer or CPA review for tax and discount lawfulness, B&O tax, mail-in, the trip fee, and any Spokane tribal license or tax?
7. Finance's 9.1% tax rate must be verified at dor.wa.gov before launch.

Tests at a glance

Area	Covers	Owner	Tests
1 Shopify and discount	Tags, product data, Function	Flow (Ryan signs in)	8

1. Shopify and discount	Tags, product data, Function runs, test-mode checkout	Flow (Ryan signs in)	3
2. Slack approve / deny	Request, buttons, lock, negative tests	Flow (Ryan clicks)	8
3. Vercel env, Redis, rate limit	Env vars, keys, 429, flag behavior, logs	Flow + Gitty	9
4. Code tests	Verify route, stub guard, Slack route, abuse, CI	Gitty	22
5. Reference check	Public tribe lists in Drive, note-only result	Drive	8
6. Finance	Discount math, margin, WA sales tax, order logging	Finance	20

On this page

Tests at a glance
1. Shopify and discount
2. Slack approve and deny
3. Vercel env, Redis, rate limit
4. Code tests
5. Reference check
6. Finance tests
Overall PASS and FAIL
Rollback steps
Open items and caveats

1. Shopify and discount tests

ID	Test	Expected result	PASS / FAIL
1.1	Tag state	Ryan's customer has tribal-member-verified. An untagged customer does not. The old Tribal_Verified tag is gone.	PASS: all three are true. FAIL: any one is not.
1.2	Product tags	20 products tagged tribal-eligible. Trip fee tagged trip-fee. The 6 iPhone batteries tagged battery-repair.	PASS: counts and tags match exactly. FAIL: any mismatch.

		tagged battery-repair.	
1.3	Bundle metafield	iPhone 16 Display + Power Combo has dcp.tribal_eligible_amount = 147 and tags bundle and tribal-eligible.	PASS: value and tags match. FAIL: any mismatch.
1.4	Function: repo tests (offline)	Repo jest suite (13 cases) passes. No live change.	PASS: 13 of 13 green. FAIL: any red.
1.5	Function: sample carts (offline)	Run with `shopify app function run`. Tagged customer: 20% on the screen only, trip fee 0, battery 0, bundle 20% of 147 only. Untagged: 0. Battery add-on beside a screen is not discounted (no stacking). combinesWith all false.	PASS: every cart matches. FAIL: any wrong amount, any discount on trip fee or battery, any stacking.
1.6	Mail-in (offline only)	No mail-in products exist yet, so mailInBundlesOnly can only be tested offline.	PASS: offline run shows mail-in discounts only on bundles. Live behavior stays untested.
1.7	Checkout before Nov 1 (Option A)	Discount is scheduled, so a test-mode checkout shows no 20%. The tag does not break checkout.	PASS: no discount shown and checkout completes in test mode. FAIL: a discount appears early, or checkout errors.
1.8	Checkout with 20% shown (Option B, or after Nov 1)	Tagged account, test mode: one screen + trip fee + battery. 20% on the screen only. Tax on the discounted price. No real charge. Option B needs Ryan's explicit OK; start is then set back to Nov 1 12:00 AM PT and verified.	PASS: line amounts match 1.5 and no charge is made. FAIL: any wrong line, or the start date is not restored.

Owner: Flow runs, Ryan only signs in. Offline runs make no live change.

Option A is recommended: 1.1 to 1.7 only. Option B (1.8) needs Ryan's explicit OK.

2. Slack approve and deny

ID	Test	Expected result	PASS / FAIL
2.1	Submit request	Submit a verification request from Ryan's account. A message appears in #tribal-approvals with Approve and Deny buttons in about 5 seconds.	PASS: one message, both buttons. FAIL: none, or duplicates.
2.2	Approve as Ryan	Customer gets the tribal-member-verified tag. The message updates once.	PASS: tag added once and message updated once. FAIL: a tag without an Approve click.
2.3	Second click	A second click does nothing (lock).	PASS: no second change. FAIL: any second decision.
2.4	Deny	No tag. Message updates. Customer sees a denied or pending state.	PASS: no tag and message updated. FAIL: a tag is applied.
2.5	Non-approver click	A click by anyone not in the approver list is rejected.	PASS: rejected, no change. FAIL: any change.
2.6	Bad Slack signature	Returns 401, no side effects.	PASS: 401. FAIL: anything else.
2.7	Replayed old timestamp	Rejected.	PASS: rejected. FAIL: accepted.
2.8	Test customer	Use a throwaway customer, not a real member, so the tag can be reset.	PASS: tag reset after the test. FAIL: a real member is touched.

Owner: Flow sets up and watches, Ryan clicks.

With the flag off the route returns 404, so this area needs the brief flag-on that Ryan approved at 2:18 PM PT, for Ryan's own tagged account only. The flag goes back off if anything fails.

3. Vercel env, Redis, rate limit

ID	Test	Expected result	PASS / FAIL
3.1	Production env present	SLACK_SIGNING_SECRET, SLACK_BOT_TOKEN,	PASS: all 8 present, no value shown. FAIL: any missing, or

		SLACK_TEAM_ID, SLACK_APP_ID, SLACK_TRIBAL_CHANNEL_ID, SLACK_TRIBAL_APPROVER_IDS, KV_REST_API_URL, KV_REST_API_TOKEN. Never print values.	any value exposed.
3.2	Other TRIBAL_* flags	Set as intended: TRIBAL_VERIFY_ENABLED off, TRIBAL_TAX_EXEMPT_ENABLED off.	PASS: both off outside the brief test. FAIL: either on.
3.3	Redis keys	Pending review at tribal:review:<id>. Lock at tribal:review-lock:<id>.	PASS: keys appear as named. FAIL: other names, or raw IDs in keys.
3.4	dcp-triage keys	dcp:* keys untouched.	PASS: unchanged. FAIL: any change.
3.5	Rate limit	Keys ratelimit:verify:<id>. Over the limit within a minute returns 429.	PASS: 429 over the limit. FAIL: no limit.
3.6	Cleanup	Entries cleared after a decision.	PASS: cleared. FAIL: stale entries.
3.7	Flag off	Route returns 404.	PASS: 404. FAIL: anything else.
3.8	Flag on, no session	Returns an auth error, not a 500.	PASS: 401 or 403. FAIL: 5xx.
3.9	Runtime logs	No errors and no secrets.	PASS: clean. FAIL: any error or any secret.

Owner: Flow with Gitty. Never print secret values.

4. Code tests

ID	Test	Expected result	PASS / FAIL
4.1	Flag gate	Off: disabled response, no Redis, Slack or Shopify call. Default is off.	PASS: both states behave this way. FAIL: any call while off.
4.2	Input validation	Missing, empty, over-long,	PASS: every case 4xx, no stack

		wrong-type ID, non-POST (405), oversized body: all 4xx with no side effects.	trace. FAIL: any 5xx or side effect.
4.3	Consent required	No consent flag: rejected, nothing stored.	PASS: both hold. FAIL: anything stored.
4.4	No raw ID stored or logged	Spy on console, logger, Redis writes and the Slack payload. Only the HMAC or last-4 appears.	PASS: raw ID appears nowhere. FAIL: it appears anywhere.
4.5	HMAC duplicate check	Same ID twice gives one pending request. Different formatting hashes the same (confirm in code). Missing secret fails closed in production.	PASS: each case holds. FAIL: two pending requests, or fails open.
4.6	Rate limiting	429 with Retry-After. Resets after the window. A Redis failure does not leave it open (confirm in code).	PASS: all hold. FAIL: open on failure.
4.7	Guests	Guest requests mean a human tags by hand. No auto-tagging.	PASS: no automatic tag. FAIL: any auto tag.
4.8	Response wording	Success only means "submitted for manual review". Never says "verified".	PASS: wording holds. FAIL: "verified" appears.
4.9	Leftover stub CI guard	Build fails if any of these appear: verifyTribalEnrollment, TRIBAL-MEMBER-20, 1826009317748, dcp_tribal_audit_salt_2026, Tribal_Verified (outside an absence test), any tribal_* cookie setter.	PASS: guard green, and a deliberate re-add fails CI. FAIL: re-add passes.
4.10	check-enrollment	Returns 501 with verified:false. Never reads or stores an ID.	PASS: 501 and nothing stored. FAIL: otherwise.
4.11	Slack signature	Valid v0 signature succeeds. Bad, missing or modified is rejected 401. Constant-time compare.	PASS: all cases. FAIL: any accepted.

4.12	Slack timestamp and replay	Older than about 5 minutes, or in the future: rejected. Replay of a used request: rejected.	PASS: rejected. FAIL: accepted.
4.13	Approver allowlist	Empty list rejects everyone. Wrong team ID or app ID rejected.	PASS: rejected. FAIL: accepted.
4.14	Decision lock	Double-click and concurrent approve/deny give exactly one outcome. Known limit: a 30-day lock if the server crashes mid-decision.	PASS: one outcome. FAIL: two outcomes.
4.15	Approve and deny tagging	Approve tags. Deny never tags. Shopify is mocked in tests.	PASS: as listed. FAIL: tag on deny.
4.16	Enumeration	No hint whether an ID was seen before, beyond the duplicate message.	PASS: timing and text match. FAIL: a difference leaks.
4.17	Injection and mentions	Injection and XSS in ID, name, notes. No Slack mention injection such as @channel.	PASS: output encoded. FAIL: any injected content works.
4.18	CSRF and origin	Origin checks on the POST. Auth required where a logged-in flow is expected.	PASS: bad origin rejected. FAIL: accepted.
4.19	Secrets scan	check:secrets passes. No wholesale cost or HMAC secret in client bundles.	PASS: none found. FAIL: any found.
4.20	Burst load	About 100 requests from one IP. Rate limit holds. No Redis or Slack flood.	PASS: limit holds. FAIL: flood.
4.21	CI	Build, typecheck, lint, check:secrets, a11y, Jest, CodeQL.	PASS: all green on the PR. FAIL: any red.
4.22	Preview deploy	Flag on with test env vars. Slack message goes to a private test channel. Curl with a bad signature is rejected.	PASS: as listed, and production flag stays off. FAIL: production flag on.

Owner: Gitty. Becomes test files in a PR only with Ryan's OK in Gitty's own chat.

5. Reference check against the public lists

ID	Test	Expected result	PASS / FAIL
5.1	Three known-good WA tribes	For example Spokane, Colville, Kalispel, with exact strings copied from the CSV first. Result: listed, matched name equals the CSV text, source and date shown, also found in ArcGIS.	PASS: all of that. FAIL: not_found, wrong tribe, or no source cited.
5.2	Name variants	Case, punctuation or short form of a known-good name: listed or possible_similar pointing at the right entry.	PASS: right entry suggested. FAIL: not_found with no suggestion.
5.3	Made-up nation	For example "Northwind Valley Nation": not_found, a human-review note, no decision.	PASS: not_found plus note. FAIL: any listed result, or any auto-reject.
5.4	Similar-looking name	Near-miss spelling, or two tribes sharing a first word: possible_similar with candidates, asks for human confirmation.	PASS: candidates listed, none picked. FAIL: auto-pick, or a confident listed.
5.5	Blocked or stale file	(a) Point at an inaccessible file. (b) Point at a copy dated before 2026-01-30. Result: source_unavailable or a stale-source warning with the date.	PASS: no guess, human-review note. FAIL: cached or guessed answer, or not_found as if the list was read.
5.6	CSV and ArcGIS disagree	A tribe in one source but not the other: the note names both sources and the disagreement.	PASS: both shown. FAIL: only one shown.
5.7	Empty or garbage input	Blank, numbers, very long text: a clear "need a tribe name" message.	PASS: message, no crash, no listing. FAIL: crash or a listing.
5.8	Note-only confirmation	No approve or deny field in code or schema. Ticket and discount state are identical before and after each test.	PASS: all four hold for tests 5.1 to 5.7. FAIL: any decision output, or any state change.

		before and after each test. Every response carries "Reference list match only. Not a membership or eligibility determination; staff decides." and a human-review flag. Drive scope is read-only.		

Owner: Drive. Read-only. Returns a note only, never approve, deny, eligible or verified-member.

Primary list: BIA CSV derived from Federal Register 91 FR 4102 (Jan 30, 2026). Cross-check: BIA Tribal Leaders Directory (ArcGIS, accessed Oct 24, 2026). Copy exact tribe names from the CSV before running.

Result fields: match_status (listed, not_found, possible_similar, source_unavailable), matched_name as printed, source file with link and modified date, similar_names, caveat. The lists show federal recognition, not whether a person is a member. The ID card, enrollment number and member status stay with staff. Spokane Tribe Enrollment Office, 509-458-6523 , is the only real proof.

6. Finance tests

Owner: Finance. Read-only. Test or draft orders only. To the cent: any mismatch FAILS and blocks launch.

A. 20% math

ID	Test	Expected result	PASS / FAIL	Owner
6.A1	Screen discount	iPhone 16 OLED $147 becomes $117.60 (discount $29.40).	PASS: exactly $117.60. FAIL: any other amount.	Finance
6.A2	Trip fee	$25 stays $25.00.	PASS: no discount. FAIL: any discount.	Finance
6.A3	Battery add-on	Line $105 minus $25 = $80.00, not discounted.	PASS: $80.00. FAIL: 20% applied.	Finance
6.A4	Screen + battery bundle	$117.60 + $80.00 = $197.60. The 20% is on the screen line only.	PASS: exactly $197.60. FAIL: any other amount.	Finance
6.A5	No stacking	Tribal plus another code gives one discount only.	PASS: second rejected or ignored. FAIL: both apply.	Finance

6.A6	Non-member	Same cart with no verification pays full price ($147 / $227).	PASS: full price. FAIL: any discount.	Finance
6.A7	Rounding	Rounded at the line level to cents. Whole-dollar rounding is not decided, so $197.60 stays unrounded until Ryan says.	PASS: matches Ryan's rule. FAIL: otherwise.	Finance
6.A8	Re-test after price change	The 20% is always 20% of the live Shopify price.	PASS: matches live price. FAIL: stale price.	Finance

B. Order margin (parts cost from dcp.part_cost, floor $38)

ID	Test	Expected result	PASS / FAIL
6.B1	Bundle in-shop	Parts $56.00: $197.60 - $56.00 = $141.60.	PASS: at least $38. FAIL: under $38.
6.B2	Bundle by mail-in	Representative mail-in cost $71.85: $69.75.	PASS: at least $38. FAIL: under $38.
6.B3	Screen-only in-shop	OLED 16, cost $39.75: $117.60 - $39.75 = $77.85.	PASS: at least $38. FAIL: under $38.
6.B4	Screen-only mail-in	At 20% off, margin is about $6.00 (OLED 16), $5.70 to $5.85 ($147 screens), $10.68 to $10.75 ($167 screens). Fails the floor by design, so mail-in tribal is bundle-only.	PASS: the site blocks or quotes it as unavailable. FAIL: it sells it.
6.B5	Every order	Margin = total charged before tax - parts - mail-in cost.	PASS: at least $38. Any order under $38 is flagged.

C. WA sales tax (TRIBAL_TAX_EXEMPT_ENABLED stays OFF)

ID	Test	Expected result	PASS / FAIL
6.C1	Flag default	TRIBAL_TAX_EXEMPT_ENABLED reads OFF before and after.	PASS: off both times. FAIL: on.
6.C2	Tribal order in	Tax on the discounted price at	PASS: tax above $0 on the

	Spokane	9.1%: $117.60 x 9.1% = $10.70. No automatic exemption.	discounted amount. FAIL: $0 tax.
6.C3	Trip fee tax	$25 fee adds $2.28 at 9.1%.	PASS: in the taxable base. FAIL: left out.
6.C4	Non-member tax	Tax on the full price.	PASS: full-price base. FAIL: otherwise.
6.C5	Mail-in return to a WA address outside Spokane	Destination rate applied. Unconfirmed; a preparer must confirm.	PASS: preparer confirms the rate. Not yet confirmed.
6.C6	Exemption claim	Gets no automatic treatment. Goes to Ryan and a preparer first.	PASS: no automatic exemption. FAIL: any.
6.C7	Tax line	Matches what Shopify shows.	PASS: matches to the cent. FAIL: any difference.

Finance has not seen the tax checklist yet: https://cursor.com/canvas/store-1d654a60-e72f-440a-937b-b477ba721dee/53924953-6743-468d-b119-7705de37f2d0

D. Logging the first real orders

The ledger stays read-only until Ryan approves writes. Log the first 10 real orders by hand and recheck each against A and B. One row per order:

- Date, order number, gross price, tribal discount
- Tax collected (a liability, not income)
- Parts cost and shipping or mail-in cost
- Shopify and payment fees (rate missing, so log the actual amount)
- Payout date and receipt link
- Do not store ID images or numbers in the books

E. Flags after launch

- Tax is $0 on any tribal order
- Discount over 20% of the screen or repair line, or on the trip fee or battery
- Stacked promos

- Any order under the $38 floor
- Refunds on discounted orders
- Shopify price or part cost changes that break the math